

Postal Address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(11)

Police Authority
Sent only by email

Decision after supervision according to the
Crime Data Act – The Police Authority's
processing of personal data when
using email

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection states that the Police Authority during the period from August 1 to August 27, 2018, processed personal data in violation of Chapter 3, Sections 2 and 8 of the Crime Data Act (2018:1177). This was done by allowing personal data, which in the event of dissemination to unauthorized persons outside the authority could have a serious negative impact on personal integrity, to be sent internally via email without the authority having taken sufficient technical and organizational measures to ensure and demonstrate that the processing of personal data is lawful and to protect the personal data being processed from unauthorized or unlawful processing.

The Swedish Authority for Privacy Protection notes that there is a risk that the technical and organizational measures taken by the Police Authority are not sufficient to meet the requirement for an appropriate level of protection in Chapter 3, Section 8 of the Crime Data Act.

The Swedish Authority for Privacy Protection therefore recommends, with support from Chapter 5, Section 6, first paragraph of the Crime Data Act, that the Police Authority take further measures to increase the level of protection regarding the handling of data.

Furthermore, the Swedish Authority for Privacy Protection notes that there is a risk that the Police Authority does not fulfill the obligation to notify the registered individuals as required by Chapter 3, Section 10 of the Crime Data Act when a personal data incident has occurred, unless measures are taken to counteract the risk. The Swedish Authority for Privacy Protection therefore recommends the Police Authority, with support from Chapter 5, Section 6, first paragraph of the Crime Data Act, to review its handling of when the authority is obliged to notify the affected registered individuals about a personal data incident.

Account of the supervisory matter

The Swedish Authority for Privacy Protection (IMY) received in September 2018 and February 2020 two reports of personal data incidents according to the Crime Data Act (ref. no. PUI-2018-859 and PUI-2020-428) from the Police Authority. The first incident report concerned email messages that had been inadvertently sent to an unauthorized person during the period from March 2016 to August 2018. According to the authority's information, approximately ten of these nearly sixty messages contained sensitive personal data, e.g., information about

Diary Number:
DI-2020-3904
Your Diary Number:
A194.851/2020
Date:
2023-01-16

suspected and victim, or information that in turn provided access to that type of information. The second incident report concerned access to a meeting calendar that was sent via email. In light of these personal data incidents, IMY initiated a review of the causes of the incidents, whether the Police Authority has sufficient routines for when personal data may be sent via email, and whether the authority has otherwise taken appropriate measures to prevent similar incidents from recurring. The review also included checking whether the Police Authority's considerations and assessments regarding the obligation to notify affected data subjects about the occurred personal data incidents have been consistent with the Crime Data Act. Information that police employees send via email can be attributed to both law enforcement activities and the Police Authority's other activities. In the former case, the provisions of the Crime Data Act apply, while the provisions of the General Data Protection Regulation¹ apply in the latter case. This supervision has been limited to a review under the Crime Data Act.

During the supervision, the Police Authority answered a number of questions from IMY and submitted relevant internal governing documents. The authority's responses indicate that the background to the incidents has mainly been that emails have been accidentally sent to unauthorized recipients due to employees at the authority mistakenly misspelling "...@polisen.se" when entering the recipient address. Furthermore, the Police Authority has stated that an external person has registered internet domains with similar spellings to polisen.se and, with a so-called catch-all function², unlawfully accessed emails that were actually intended for police employees. According to the authority, this came to its attention when the domain owner contacted the authority and informed them.

The Police Authority has stated that the internal guidelines that existed even before the incident report in September 2018 indicate that information within the information classes open to very high protection value may be sent internally via email within the authority. However, information with a very high protection value is not allowed to be sent in this manner. Furthermore, it is stated that only information classified as open may be sent to external recipients via regular email (i.e., without any form of encryption solution).

The guidelines indicate that the information class high protection value refers to information that could cause serious harm or violation to the Police Authority, another authority, or an individual physical or legal person if it comes to the knowledge of unauthorized persons. Furthermore, it is stated, as an example of information with a high protection value, sensitive personal data according to the Personal Data Act (i.e., the law that was in effect before the General Data Protection Regulation came into force), information regarding violations of the law, or similar information.

In the guidelines, the information class very high protection value is described as information that could cause very serious harm or violation to someone if the information comes to the knowledge of unauthorized persons.

On October 1, 2022, the older guidelines were replaced by new ones. These indicate that it is still permissible to send information in the information classes open to high protection value.

¹ Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

² The function means that all emails will go to the domain owner regardless of what is specified before the @ sign.

3(11)

Date: 2023-01-16

The protection value internally within the authority via email is emphasized, but it is recommended that shared directories are primarily used for file sharing, and the importance of verifying the recipient address is underlined. In the new guidelines, the term negative consequence is used instead of harm/infringement, and it has been clarified that an assessment should be made regarding whether the disclosure of the information may have a negative impact on privacy. The information has a high protection value if a disclosure is assessed to result in a serious negative impact on personal privacy, and a very high protection value if it is assessed to result in a very serious such impact. Sensitive personal data or personal data concerning violations of the law are not specifically mentioned under any of the information classes.

The Police Authority has described that the authority has implemented a number of security measures to prevent emails from being accidentally sent to unauthorized persons. Even before the first incident report, there was a requirement that an employee must apply for authorization to be able to send emails externally, and, just as now, an automatic warning message appeared in the form of a notice above the recipient address indicating that the recipient is outside the organization when an employee enters an external recipient address. Furthermore, the authority has stated that an email address for a recipient outside the organization, prior to the first incident report, automatically receives a different color than if the recipient address goes to an employee within the authority. On August 28, 2018, the Police Authority implemented a technical barrier, in the form of a filter in the police IT environment, which stops the possibility for employees within the police to send emails to, among others, a number of different domain names that resemble @polisen.se. It is evident from the submitted material that this barrier has been continuously updated with other possible misspellings.

The authority has further indicated that after the first incident report, it posted information on the internal website to make employees aware of the importance of entering the correct recipient address. The authority has also, after the first incident report, introduced mandatory training on, among other things, security in email handling that all employees with access to the authority's IT systems, e.g., authorization to send emails externally, must complete. Additionally, it has been described that further information about security in sending emails has been published on the internal website since the later incident and that more measures will be taken, such as more information campaigns and training, as well as the establishment of a new guideline for how employees should act in the event of personal data incidents. The guideline is said to increase the authority's ability to detect and manage similar incidents and to take further concrete measures to prevent such incidents. The authority has also stated that they have a guideline for data protection in operational development, among other things, to ensure that a legal assessment is made regarding the extent to which email may be used in new or changed processing of personal data.

The Police Authority has assessed that regarding both personal data incidents, there was no obligation to notify the affected data subjects about the incident according to Chapter 3, Section 10, first paragraph of the Crime Data Act, as the incidents could not be assumed to pose a specific risk of improper intrusion into the personal privacy of the data subjects. What the authority has further stated regarding this assessment is outlined below.

Page 3 of 11

Integrity Protection Authority

Diary Number: DI-2020-3904

4(11)

Date: 2023-01-16

Justification of the Decision

The Police Authority's Obligation to Implement Technical and Organizational Measures to Protect Personal Data Sent via Email

Applicable Provisions

The Police Authority is, according to Chapter 3, Section 1 of the Crime Data Act and Chapter 1,

Section 4 of the Act (2018:1693) on the Police's Processing within the Scope of the Crime Data Act, the data controller for all processing of personal data carried out under the authority's management or on behalf of the authority. As the data controller, the Police Authority is responsible for ensuring that the processing of personal data within the authority is compliant with legislation and adheres to the fundamental principles for the processing of personal data. As part of this responsibility, the Police Authority must, according to Chapter 3, Section 2 of the Crime Data Act, implement appropriate technical and organizational measures to ensure and demonstrate that the processing is carried out in accordance with the provisions of the Crime Data Act. This means, for example, that there must be clear routines and guidelines for employees' processing of personal data when using email. Chapter 3, Section 1 of the Crime Data Ordinance (2018:1202) states that the technical and organizational measures that the data controller must take should be reasonable considering the nature, scope, context, and purpose of the processing, as well as the specific risks associated with the processing.

Furthermore, Chapter 3, Section 8 of the Crime Data Act prescribes an obligation to take appropriate technical and organizational measures to protect the personal data being processed against, among other things, unauthorized or unlawful processing. Such measures may include, for example, controls, training in data security, and information about the importance of adhering to applicable security routines. The measures must, according to Chapter 3, Section 11 of the Crime Data Ordinance, achieve a level of protection that is appropriate considering technical possibilities, costs of the measures, the nature, scope, context, and purpose of the processing, the specific risks associated with the processing, and how sensitive the personal data being processed is. Chapter 3, Section 3 of the Crime Data Act also establishes an obligation to ensure that protective measures are integrated into the processing when determining the means for processing and during the actual processing.

IMY's Assessment

From the incident report that occurred in September 2018, it is evident that employees of the Police Authority unintentionally disclosed personal data concerning, among others, individuals who were subjects of criminal suspicions or involved in criminal investigations, in connection with the processing of data in email. The report indicates that the incident took place between March 28, 2016, and August 9, 2018. Thus, the incident largely occurred before the Crime Data Act came into force on August 1, 2018.

In the supervision, it has been revealed that the Police Authority, at the time of the first incident report, had guidelines that outlined how and when data could be sent via email. These guidelines have recently been replaced by new ones. According to both the older and the new guidelines, the assessment of how the information is classified based on its protection value is crucial for the question of how the data may be sent and handled in the email system. Both sets of guidelines indicate that information with a classification from open to high protection value may...

3 See Prop. 2017/18:232 Crime Data Act p. 457 f.

Page 4 of 11

Swedish Authority for Privacy Protection

Diary Number: DI-2020-3904

5(11)

Date: 2023-01-16

is sent internally via email within the authority. As described above, the information class of high protection value is defined in different ways in the two guidelines. However, IMY has understood that the new definition does not imply any significant difference compared to the previous one regarding the assessment of how personal data may be sent. The new guidelines clarify, however, that any impact on privacy is one of the factors to be considered in the assessment.

IMY notes from this that the Police Authority, both according to its previous and current guidelines, allows personal data, which in the event of disclosure may cause a serious negative impact on someone's personal privacy, to be sent internally via email. Thus, personal data that is particularly sensitive in terms of privacy is permitted to be sent via email internally, unless the data in the individual case is assessed to have a very high protection value, despite the fact that it is possible within the

same system to send emails to external recipients. This may, for example, involve sensitive personal data, personal data concerning violations of the law, or similar categories of personal data such as personal identification numbers, protected personal data, or information that someone is a victim or witness. The reported incidents also show that personal data within these categories were processed in internal emails. The processing of such personal data is particularly sensitive when it occurs within the operational activities of the Police Authority, i.e., for crime-fighting and crime-investigating purposes. The dissemination of such data can have far-reaching consequences for individuals, as it may lead to damaged reputation, threats and violence, discrimination, identity fraud, or violations of confidentiality regulations.

It should also be emphasized that personal data incidents are often caused by the human factor. By allowing personal data that, in the event of disclosure, may cause a serious negative impact on someone's personal privacy to be sent internally via email, the authority also has a significant responsibility to take measures that ensure a security level that is appropriate in relation to the risk associated with the processing.

This means that very high demands must be placed on the technical and organizational measures that the Police Authority needs to implement according to Chapters 3, Sections 2 and 8 of the Crime Data Act to protect the rights of the registered individuals and the personal data being processed.

From the Police Authority's response to IMY, it is clear that what determines whether an email is sent internally to an internal recipient or via the open network to an external recipient is the specification of the recipient's address. The recipient address thus has a decisive significance for the level of protection that the data in the email message receives.

The Police Authority has stated that prior to the incident report in September 2018, it had implemented a number of security measures to prevent employees from accidentally sending emails to unauthorized external recipients by incorrectly specifying an external email address instead of an internal one. The measures described in more detail above mean that an automatic warning message appears and that the email address is highlighted in a different color when a

4 Sensitive personal data includes, among other things, information about ethnic origin, political opinions, health, or biometric data. See Chapters 2, Sections 11-12 of the Crime Data Act.

5 Personal data concerning violations of the law includes, for example, that someone is suspected of a crime or has been subject to coercive measures in criminal proceedings. See also IMY's legal position IMYRS 2021:1 - the meaning of the term "personal data concerning violations of the law that involve crime" in Article 10 of the Data Protection Regulation.

6 See IMY's report Reported Personal Data Incidents 2022:1 p. 19

Page 5 of 11

Swedish Authority for Privacy Protection

Diary Number: DI-2020-3904

6(11)

Date: 2023-01-16

An external email address is specified, and special authorization is required to send emails externally.

IMY's assessment is that the technical measures that were implemented prior to the first incident report, i.e., warning messages and a different color for the recipient address, are such that they can easily be overlooked unintentionally by the employee. It can be noted that during this period there was no technical barrier against sending to external email addresses that resemble the Police Authority's own email addresses. Therefore, there was a significant risk that employees, by inadvertently entering an external email address instead of an internal one, would send personal data intended for an internal recipient to unauthorized persons. According to the reported personal data incidents, this has also occurred on several occasions, demonstrating that the measures have not been sufficiently effective in limiting the risk of personal data being mistakenly sent to external recipients. Against this background, IMY assesses that the technical and organizational measures that the Police Authority had implemented at the entry into force of the Crime Data Act on August 1, 2018, and until the end of

August 2018, were not sufficient to meet the requirements of Chapter 3, Sections 2 and 8 of the Crime Data Act.

The Police Authority has described that after the incident report in September 2018, it implemented a number of additional security measures. The authority has, for example, conducted training and information initiatives to raise employee awareness of the importance of entering the correct recipient address. This is also particularly emphasized in the new guidelines. Furthermore, the authority has, as indicated above, introduced a technical barrier at the end of August 2018 that captures and stops emails sent to domain names resembling @polisen.se. The authority has stated that the barrier is continuously expanded with more potential misspellings of domains. Additionally, the authority has explained that the technical barrier was not activated during the incident that occurred in 2020 because the email at that time was not sent from the Police Authority's email system.

The measures that the Police Authority has taken after the first incident report have raised the security level, and IMY places particular emphasis on the technical barrier, i.e., the function that captures and stops email messages, which has been introduced to counteract the risk of personal data being unintentionally spread to unauthorized recipients. However, according to IMY, there remains uncertainty as to whether the measures taken collectively ensure an appropriate level of protection and are sufficiently effective to prevent new similar incidents. As IMY has noted above, very high demands are placed on the technical and organizational measures that the Police Authority needs to implement for the relevant processing.

IMY further notes that there are additional security measures that may be reasonable to consider. This could, for example, involve completely separating the email that goes internally within the authority from the email that goes externally or introducing technical controls that require the employee to actively confirm that they are aware that the message will be sent to an external recipient via an open network and confirm that it has been ensured that the information is such that it can be sent externally. Another option could be that the authority does not allow personal data that is deemed to have a high protection value to be sent internally via email. In this case, no technical obstacles or cost aspects have emerged that argue against the Police Authority's ability to implement additional security measures to strengthen protection.

Page 6 of 11

Swedish Authority for Privacy Protection

Diary Number: DI-2020-3904

7(11)

Date: 2023-01-16

IMY assesses that there are reasons to believe that the Police Authority needs to take further measures to meet the requirement for an appropriate level of protection in Chapter 3, Section 8 of the Crime Data Act and Chapter 3, Section 11 of the Crime Data Regulation. There is thus a risk that the Police Authority will process personal data in violation of these provisions. However, according to IMY, the investigation in the matter does not provide sufficient support to establish a violation of the provisions.

The Police Authority's obligation to notify affected data subjects of a personal data incident

Applicable provisions

According to Chapter 3, Section 10, first paragraph of the Crime Data Act, the data controller shall inform the data subject without undue delay about an incident if it has resulted in or is likely to result in a specific risk of improper intrusion into the data subject's personal integrity. There are a number of exceptions to this notification obligation, which follow from the second paragraph of the section and Chapter 3, Section 11 of the Crime Data Act. The purpose of the notification is primarily to enable the data subject to take necessary measures to protect themselves.

IMY's assessment

This supervision has been initiated against the background that the Police Authority has made two reports of personal data incidents to IMY, and within the framework of the supervision, IMY has

reviewed the considerations and assessments made by the Police Authority regarding the question of whether there is an obligation to notify the affected data subjects about the incidents or not. The reports have in both cases been made against the background of the provisions of the Crime Data Act, as the incidents mainly concerned personal data that the Police Authority processed within the framework of law enforcement activities.

It is the responsibility of the Police Authority as the data controller to assess in each individual case whether there is an obligation to notify the data subjects about a personal data incident. In the assessment, consideration should be given to how serious the consequences may be for the data subject due to the incident and how likely it is that these consequences will occur, taking into account the nature, scope, context, and purpose of the processing. The so-called Article 29 Working Party, which has now been replaced by the European Data Protection Board, has developed guidelines on the notification of personal data incidents under the General Data Protection Regulation (WP250 rev0.1). The guidelines are, in applicable parts, also guiding for personal data processing under the Crime Data Act. The guidelines recommend that a data controller takes into account the following criteria in the risk assessment: the type of incident, the nature of the personal data, sensitivity and volume, how easy it is to identify individuals, the severity of the consequences for individuals, the specific characteristics of the individual, the

7 See Recital 62 of the European Parliament and Council Directive (EU) 2016/680 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of preventing, investigating, detecting, or prosecuting criminal offenses or executing criminal penalties, and the free flow of such data, and repealing Council Framework Decision 2008/977/JHA (the Crime Data Directive).

8 See Recital 52 of the Crime Data Directive.

9 EDPB has developed supplementary guidelines (Guidelines 01/2021 on Examples regarding Personal Data Breach Notification) containing several examples of personal data incidents and how the data controller should handle these.

Page 7 of 11

Swedish Authority for Privacy Protection

Diary Number: DI-2020-3904

8(11)

Date: 2023-01-16

the special characteristics of the data controller, the number of individuals affected, and other general aspects.¹⁰

The Police Authority has assessed that there was no obligation to notify the data subjects regarding the incidents, as the incidents could not be assumed to pose a specific risk of improper intrusion into the personal privacy of the data subjects.

According to the incident report from 2018, an unauthorized person gained access to nearly sixty emails, of which ten contained sensitive personal data, including information about crimes, according to the Police Authority. The Authority has stated that the assessment regarding the obligation to notify in that case was made against the background that there was no reason to assume that the unauthorized individual intended to use or disseminate the information, as they themselves contacted the Police Authority and reported the incident.

According to the incident report from 2020, it involved an email containing login details to a booking calendar for interrogations that was received by an unauthorized person. The calendar reportedly contained certain sensitive personal data, according to the Police Authority. Regarding this event, the Police Authority has indicated that in assessing whether there is an obligation to notify, it was considered that the booking calendar contained only a very small portion of data that could identify any data subject and that this data was very difficult to find for an ordinary user, and that it was still unclear what interrogation role the data subject had or what crime was involved. Furthermore, the Authority also took into account that the data was available only for a limited time, as the Authority deleted it shortly after the incident became known, and that, even in this case, there were no indications that the

data would be saved, disseminated, or used.

According to IMY, the following should be considered when assessing the risk of improper intrusion into the personal privacy of the data subjects due to the incidents in question. In both incidents, it involved particularly sensitive personal data, such as personal data concerning restraining orders or summonses to police interrogations, which unauthorized individuals gained access to. This is especially true for the earlier incident in 2018, as the incident in 2020, according to the Authority, involved a limited number of data. In both cases, the data was sent unencrypted over an open network, which meant that others besides the direct recipient could access the data communicated over the network. Therefore, it is not possible, as the Police Authority has done, to conclude that the data became available through the incidents only to one unauthorized person.

It has further emerged that the Police Authority has considered the recipient's intentions in its risk assessment. The Article 29 Working Party mentions in its guidelines that a recipient who is deemed "trusted" can make the incident less serious. According to the guidelines, a trusted recipient is one where the data controller can be reasonably sure that the recipient will not read or attempt to access the data that was mistakenly sent to them or take further action with the data, but will instead follow the data controller's instructions to, for example, destroy the data. An example of when a recipient may be considered trusted is a situation where data has been mistakenly sent to the wrong department within an organization or a frequently used supplier, and where the data controller has an ongoing

10 Article 29 Working Party's guidelines on the notification of personal data breaches under Regulation (EU) 2016/679, WP250 rev.01, p. 25 ff.

Page 8 of 11

Swedish Authority for Privacy Protection

Diary Number: DI-2020-3904

9(11)

Date: 2023-01-16

relationship with the recipient and is aware of their routines, history, and other relevant details.¹¹ IMY can ascertain that this has not been a situation in the current cases, nor a situation that can be compared to the specified examples.

Against this background, IMY finds that there are deficiencies in the risk assessments that the Police Authority has undertaken as a basis for determining whether there was an obligation to notify the registered individuals about the personal data incidents in these cases.

The circumstances suggest that this constitutes a systematic deficiency in how risk assessments are conducted at the Police Authority. IMY therefore concludes that there is a risk that the Police Authority will not fulfill its notification obligation according to Chapter 3, Section 10 of the Crime Data Act unless the authority takes measures to counteract that risk.

Choice of Intervention

Corrective Powers

According to Chapter 5, Section 7 of the Crime Data Act, the corrective powers available to IMY in cases of violations of the aforementioned law are specified. These include, among other things, orders, prohibitions against processing, and the imposition of administrative fines.

Above, IMY has established that the Police Authority, during the period from August 1 to August 27, 2018, violated Chapter 3, Sections 2 and 8 of the Crime Data Act. According to Chapter 6, Sections 1 and 2 of the Crime Data Act, IMY can impose an administrative fine for violations of these provisions. Chapter 6, Section 4 of the Crime Data Act specifies the factors that should be particularly considered when determining whether an administrative fine should be imposed and what should influence the amount of the fine. This provision states that IMY should particularly take into account whether the violation was intentional or due to negligence, the damage, danger, or infringement that the violation has caused, the nature, severity, and duration of the violation, what the data controller has done to limit the effects of the violation, and whether the data controller has previously been ordered to pay an administrative fine. The enumeration is not exhaustive but indicates the circumstances that are particularly important.

IMY shall, depending on the circumstances of each individual case, choose a corrective measure that is effective, proportionate, and deterrent.

IMY notes that the violation of the provisions of the Crime Data Act has lasted for almost a month and that it may have serious consequences for the registered individuals considering that it concerns personal data which, if disseminated, can pose significant risks to the intrusion of personal privacy. The identified deficiency has resulted in at least one unauthorized person gaining access to a number of personal data that were particularly sensitive in terms of privacy. The fact that the Police Authority became aware of the incident only when the individual voluntarily contacted the authority indicates that the authority has not had full control over how often emails have been incorrectly sent outside the authority instead of internally, which means it may have occurred on more occasions than what is reflected in the incidents reported to IMY. Against this background, it is difficult to assess how many registered individuals have been affected by their personal data being inadvertently sent to an email address outside the authority during the time of the current violation of the Crime Data Act. Regarding any potential

11 See previous note p. 26.

Page 9 of 11

Swedish Authority for Privacy Protection

Case Number: DI-2020-3904

10(11)

Date: 2023-01-16

damage, there have not been conditions within the framework of supervision to further investigate whether the violations have led to any actual damage to individuals.

At the same time, it should be noted that the Police Authority has taken several technical and organizational measures both before and after the incidents were reported to IMY, which indicates that the authority is working continuously and systematically with information security concerning the processing of personal data that the supervision pertains to.

Upon a comprehensive assessment, IMY believes that it is not proportionate to impose a sanction fee for the identified deficiency. Neither is it relevant to issue an injunction or warning as the identified deficiency is not ongoing.

Preventive Powers

If there is a risk that certain personal data processing may conflict with the law or other regulations, IMY shall, through the preventive powers that follow from Chapter 5, Section 6 of the Crime Data Act, attempt to persuade the data controller to take measures to counteract that risk. This can be done through advice, recommendations, or remarks. If it is not deemed sufficient, IMY also has the option to issue a warning.

IMY has concluded above that there is a risk that the technical and organizational measures taken by the Police Authority are not sufficient to meet the requirement for an appropriate level of protection according to Chapter 3, Section 8 of the Crime Data Act and Chapter 3, Section 11 of the Crime Data Ordinance.

Furthermore, IMY has concluded, as stated above, that there is a risk that the Police Authority does not fulfill the obligation to notify that follows from Chapter 3, Section 10 of the Crime Data Act when a personal data incident has occurred, unless measures are taken to counteract this.

None of the risks are of such a nature that IMY finds it justified to issue a warning. However, IMY finds reason to recommend that the Police Authority take additional measures to raise the level of protection and prevent personal data, which may have a serious negative impact on personal integrity, from being disseminated via email to unauthorized persons outside the authority, and also to review its handling of when the authority is obliged to notify affected data subjects about a personal data incident.

This decision has been made by the unit manager Charlotte Waller Dahlberg after presentation by the lawyer Jonas Agnvall. In the final handling of the case, the legal manager David Törngren and the

lawyer Lisa Zettervall, as well as the IT security specialist Magnus Bergström, have also participated.
Charlotte Waller Dahlberg, 2023-01-16 (This is an electronic signature)

Copy for information to:

The Data Protection Officer of the Police Authority

Page 10 of 11

Swedish Authority for Privacy Protection

Case Number: DI-2020-3904

11(11)

Date: 2023-01-16

How to Appeal

If you wish to appeal the decision, you should write to the Swedish Authority for Privacy Protection. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by the Swedish Authority for Privacy Protection no later than three weeks from the day the decision was communicated. If the appeal is submitted in a timely manner, the Swedish Authority for Privacy Protection will forward it to the Administrative Court in Stockholm for examination. You can email the appeal to the Swedish Authority for Privacy Protection if it does not contain any privacy-sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.

Page 11 of 11